INFORME DE VERIFICACION - HU-4.3 / NIKTO
Proyecto: Titulos Universitarios Digitales
Fecha: 10 de octubre de 2026 | Version: actualizado con escenarios ejecutados

RESUMEN
Se ejecutaron la bateria estandar de Nikto y comprobaciones manuales HTTP para HU-4.3. La ruta /login responde 200 con CSP, Referrer-Policy y Permissions-Policy. Las rutas privadas /titulos y /actuator/health redirigen a /login sin autenticar. Nikto completo: 8,198 solicitudes, 0 errores, 2 observaciones. Maven: 14/14 tests correctos. La validacion visual del navegador y HSTS sobre HTTPS quedan pendientes.

ESCENARIOS EJECUTADOS
E1 - GET /login (T-4.3.2): HTTP 200. CSP, Referrer-Policy y Permissions-Policy presentes; se observaron tambien X-Content-Type-Options: nosniff y X-Frame-Options: DENY. Cookie JSESSIONID incluye HttpOnly.
E2 - CSP en login: politica recibida con default-src self, script-src self, style-src self unsafe-inline, frame-ancestors none y base-uri self. La pagina HTML fue servida (200); la consola visual del navegador no se inspecciono.
E3 - Acceso sin autenticar a /titulos: HTTP 302 a /login (proteccion observada).
E4 - Acceso sin autenticar a /actuator/health: HTTP 302 a /login (proteccion observada; no se probo con el rol APROBADOR).
E5 - Nikto 2.6.1 contra la instancia local HTTP:8080: 8,198 solicitudes, 0 errores. Sin banner de servidor y sin directorios CGI detectados.

RESULTADOS / LIMITES
HSTS: Nikto lo marca ausente en HTTP. SecurityConfig lo configura con max-age de 31536000 segundos e includeSubDomains, pero Spring solo lo envia por HTTPS. La aplicacion no tiene HTTPS activo en esta prueba; criterio HSTS no verificado.
Hallazgo 100.100.100.200/latest/meta-data: no reproducido manualmente. La ruta responde con redireccion al login local; la solicitud absoluta de prueba devolvio HTTP 400 sin encabezado Location con esa IP. Se considera falso positivo probable.
T-4.3.2 pide tambien confirmar visualmente la pagina sin errores CSP en consola. No se ejecuta esa comprobacion visual en este entorno; queda pendiente manual.

PRUEBAS DEL PROYECTO
Comando: .\mvnw.cmd clean test (JDK 21). Resultado: BUILD SUCCESS; 14 tests, 0 fallos, 0 errores, 0 omitidos. Son pruebas generales; no sustituyen la prueba visual del navegador ni la comprobacion HSTS sobre HTTPS.

CONCLUSION

Implementacion observada: CSP, Referrer-Policy y Permissions-Policy llegan a /login y las rutas privadas redirigen al login. El escaneo no confirma una vulnerabilidad explotable. HU-4.3 queda parcialmente validada: falta probar la vista en navegador y HSTS bajo HTTPS. El PDF se actualiza para reflejar estos escenarios y resultados.
Objetivo escaneado: http://172.28.160.1:8080 (gateway WSL hacia la app local). La IP gateway puede cambiar al reiniciar WSL.